INFORME TÉCNICO DEL SISTEMA IPSPUPTM

Arquitectura, módulos, estado de seguridad y plan de corrección técnica

Fecha: 10/11/2026 · Versión 2.0 · PHP 8.2.12 · MariaDB 10.4.32 · Apache / XAMPP · Rama: dianys
Audiencia: equipo técnico · Guía de redacción: Arquitectura de la Comunicación Técnica · Anexo: PROBLEMAS.md

1. DESCRIPCIÓN GENERAL Y ALCANCE

IPSPUPTM es una aplicación web de previsión social en PHP 8.2 procedural sobre MySQLi, sin framework, con Apache y MariaDB 10.4 (XAMPP). Cubre afiliación, beneficiarios, comunidad externa, citas, planes y pagos, pólizas, historias médicas, reportes y configuración. El código propio suma 166 archivos PHP (17.631 líneas) y 16 archivos JavaScript (15.113 líneas); la base de datos ipsp contiene 27 tablas con claves foráneas y borrado en cascada.

166	27	8	3
archivos PHP	tablas en ipsp	módulos operativos	roles de acceso

2. ARQUITECTURA, MÓDULOS Y DATOS

- Enrutamiento: home.php selecciona la vista con ?vista=; config/actions.php valida la sesión; config/permisos.php define el rol por vista; recursos/layout.php compone la interfaz y el menú.
- Organización: app/ agrupa los módulos; Inicio/ y vistas/ concentran autenticación y recuperación; config/ centraliza conexión, permisos y acciones; assets/ integra FPDF, PhpSpreadsheet, PhpWord, Dompdf, Bootstrap y Alertify.
- Persistencia: MySQLi con consultas preparadas en algunos flujos y concatenación en otros; 27 tablas con FK y borrado en cascada; bitácora de auditoría y transacciones en las altas críticas.

Módulo	Componentes y tablas principales
Pacientes	afiliados, beneficiarios, comunidad_uptm, persona; contratos y grupo familiar.
Citas	citas + citas_afil, citas_benef, citas_uptm y citas_examenes; disponibilidad y exámenes.
Pagos	planes, componentes_planes, contrato_plan, pagos_contrato, consumo_plan y pagos_externos.
Historias y reportes	historias_medicas e historias_medicas_gine; reportes PDF/Excel/Word; usuarios, bitácora y respaldo.

Reglas: pago inicial del 30 %, 3 meses de gracia, tolerancia de 2 meses de deuda y saldo de póliza = cobertura - consumos. Los descuentos se calculan en JavaScript sin revalidación en servidor.

3. ESTADO DE SEGURIDAD

La auditoría registró 118 ítems verificables: 9 corregidos y 109 abiertos, de los cuales 43 son de seguridad crítica. Ya se cerraron el bypass de recuperación de contraseña y el registro público de administradores. Persisten los riesgos de la tabla: más de 25 endpoints sin guard, consultas concatenadas, XSS, ausencia de CSRF y respaldo con credenciales expuestas.

118 ítems auditados · 9 corregidos · 109 abiertos · 43 de seguridad crítica (P1)

Hallazgo	Ubicación	Severidad	Corrección
Endpoints sin sesión ni rol	app/reportes, pagos, configuración y comunidad	Crítica	Guard central
SQL por concatenación	Procesadores y consultas de varios módulos	Crítica	Prepared statements
XSS y ausencia de CSRF	Vistas, formularios y endpoints de escritura	Alta	Escape + tokens
Respaldo y credenciales	respaldo.php; respuestas de seguridad en texto plano	Alta	Respaldo seguro + hash

4. PLAN DE CORRECCIÓN TÉCNICA

Fase	Acción técnica	Alcance	Horas
1	Guard central de sesión y rol	25+ endpoints	20 h
2	Prepared statements y validación en servidor	Consultas y altas	30 h
3	Escape de salida, CSRF y POST en mutaciones	Vistas y formularios	20 h
4	Respaldo protegido, hash de respuestas y errores	Configuración	15 h
5	Pruebas de regresión API + interfaz	Todos los módulos	15 h
Total	Plan completo	4 semanas	100 h

5. GOBIERNO ÉTICO DE LA IA

- Transparencia y supervisión: este informe se elaboró con asistencia de IA (~40 % estimado); cada métrica, comando y recomendación se contrasta contra el repositorio y la BD. El algoritmo no firma cambios: los valida el responsable técnico.
- Privacidad y calidad: no se enviaron datos de pacientes, credenciales ni copias de la BD a modelos públicos; el código generado se prueba antes de integrarse y se revisan sesgos y dependencias.
- Pipeline: entrada sin datos sensibles; procesamiento con pruebas de seguridad; salida con revisión humana y aviso de transparencia.

6. CONCLUSIONES TÉCNICAS

El sistema es funcional y ya cerró sus dos vulnerabilidades más graves. El riesgo restante es conocido y corregible: 70 de los 109 hallazgos abiertos son de seguridad y lógica de negocio. La prioridad es el guard central y las consultas preparadas; después, CSRF/XSS y el respaldo. El detalle de los 118 ítems está en PROBLEMAS.md.

PRÓXIMO HITO: crear config/auth_guard.php e incluirlo en los 25+ endpoints.

Criterio de aceptación: sin sesión -> 302/403; con rol incorrecto -> 403; ninguna escritura ni descarga antes de validar.

Metodología: revisión de código, base de datos en vivo y pruebas funcionales (API + interfaz). Criterios de redacción: precisión, claridad y objetividad. Documento de una página.
Transparencia IA: análisis y redacción asistidos (~40 % estimado); métricas contrastadas contra repositorio y BD; validación y firma humana pendientes.